INFORME DE AUDITORÍA DE CIBERSEGURIDAD

Evaluación de Vulnerabilidades e Infraestructura

Cliente:
ShopCloud S.L.

Equipo Auditor:
Xavier Margalef Riestra

Fecha:
14 de julio de 2026

Clasificación:
RESTRINGIDO

Propiedad de ShopCloud S.L. Prohibida su reproducción o distribución fuera del alcance del proyecto.

Contents

0. Control de Distribución y Guía de Lectura

Este documento técnico se ha estructurado para agilizar la revisión según el área de responsabilidad dentro de la organización:

- **Dirección (CEO, COO, Gerencia):** Revisar la sección **1. Resumen Ejecutivo** para evaluar la estimación de pérdidas económicas y el semáforo de hallazgos en menos de 5 minutos.
- **Responsables de Tecnología (CISO, CIO, CTO):** Evaluar directamente la sección **2. Top 3 Hallazgos Críticos** y coordinar la revisión del Write-up de campo con sus respectivos anexos.
- **Administración de Sistemas y Desarrollo (SysAdmins, Devs):** Ejecutar las contenciones y remediaciones operativas detalladas en la sección **3. Plan de Acción y Remediación** de manera inmediata.
- **Cumplimiento y Legal (DPO, Asesoría Jurídica):** Analizar la sección **4. Evaluación de Cumplimiento Legal** para comprobar el impacto normativo ante posibles brechas de datos.

1. Resumen Ejecutivo (Apto para Dirección)

Este informe recoge los resultados de la auditoría de ciberseguridad realizada sobre la infraestructura del comercio electrónico de **ShopCloud S.L.** El motivo de la auditoría ha sido ejecutar un análisis web y un test de penetración de caja negra (*Pentesting*) sobre el perímetro público y los entornos locales de la organización para identificar fallos antes de que actores maliciosos los aprovechen para comprometer la continuidad del negocio.

Las pruebas ejecutadas confirman que se ha logrado comprometer el servidor web externo mediante la explotación de un componente vulnerable, exfiltrar la base de datos con las contraseñas de las cuentas de administración de clientes y vulnerar localmente el sistema operativo hasta obtener privilegios totales de superusuario (*Root*). El encadenamiento de estos fallos expone directamente la continuidad de las operaciones diarias de la empresa.

Estimación de Pérdidas Económicas

- **Pérdida por parada de la tienda online (48 horas): 45.000 €.**
- **Gastos de mitigación, forense y respuesta a incidentes: 15.000 €.**

Table 1.1: Clasificación y Estado de los Hallazgos Detectados

Clasificación del Hallazgo	**Hallazgo**	**Semáforo**
No Conformidad Mayor	Ejecución Remota de Código (RCE) en WP File Manager	**Crítico**
No Conformidad Mayor	Inyección SQL (SQLi) en Formulario de Login	**Crítico**
No Conformidad Menor	Escalada de Privilegios Local vía Bit SUID en Base64	**Alto**

2. Top 3 Hallazgos Críticos (Technical Findings)

A partir de los resultados obtenidos mediante el uso de herramientas de asistencia técnica para auditoría (CAATs), se han seleccionado las tres deficiencias más graves de la plataforma:

2.1 Ejecución Remota de Código (RCE) en WP File Manager

Nivel de Riesgo: **Crítico** (Puntuación Base CVSSv3: 10.0)
Descripción breve: El perímetro web expone públicamente el componente desactualizado *WP File Manager v6.8*. Un atacante externo puede llamar directamente al script conector de la librería interna (`connector.minimal.php`) para subir archivos PHP arbitrarios de forma no autenticada, logrando ejecutar comandos a nivel de sistema operativo y obteniendo acceso inicial con el usuario del servicio web `www-data`. (Referencia: CVE-2020-25213 / Alertas INCIBE / MITRE ATT&CK T1190 - Exploit Public-Facing Application).

2.2 Inyección SQL (SQLi) y Almacenamiento Inseguro en Login de Clientes

Nivel de Riesgo: **Crítico** (Puntuación Base CVSSv3: 9.8)
Descripción breve: El formulario técnico `login.php` procesa los parámetros de entrada concatenándolos directamente en las consultas MariaDB sin pasar por un proceso de sanitizado. Al introducir caracteres de control, la aplicación devuelve un *Stack Trace* con fallos del backend, permitiendo evadir el login e interactuar con la base de datos `db_shopcloud_prod` para volcar las tablas. Las credenciales de administrador se almacenaban con hashes MD5 obsoletos y la cuenta `admin_test` directamente en texto plano. (Referencia: MITRE CWE-89: SQL Injection / CWE-256: Plaintext Storage of Passwords).

2.3 Escalada de Privilegios Local por Configuración Insegura de Bit SUID

Nivel de Riesgo: **Alto** (Puntuación Base CVSSv3: 7.8)
Descripción breve: Tras comprometer el entorno con el usuario con bajos privilegios `www-data`, se detectó que el binario del sistema `/usr/bin/base64` tiene asignados permisos especiales de ejecución SUID bajo el propietario `root`. Abusando de este fallo de configuración de infraestructura según los vectores documentados en la plataforma GTFOBins, es posible realizar una lectura de archivos restringidos, comprometiendo la seguridad del fichero `/etc/shadow` para extraer los hashes de contraseñas de Linux. (Referencia: MITRE CWE-269: Improper Privilege Management).

3. Plan de Acción y Remediación (Mitigación)

Pasos esenciales para corregir los fallos de seguridad identificados en la infraestructura de ShopCloud S.L. y prevenir su reexplotación:

3.1 Mitigación del RCE en WP File Manager (AUD-001)

- **Acción de Contención Inmediata:** Borrar o cambiar el nombre de la carpeta del plugin dentro del servidor, que está en la ruta `/var/www/html/wp-content/plugins/wp-file-manager/`, para cortar el acceso al atacante.
- **Acción Correctiva Definitiva:** Actualizar el plugin a la versión **6.9** o una más reciente donde el fallo ya esté solucionado por el creador. Además, se recomienda revisar los archivos que se suben a la web antes de que se guarden en el servidor e instalar un firewall básico para bloquear peticiones extrañas a archivos como `*.minimal.php`.
- **Responsable:** Administrador de Sistemas Senior / Operaciones IT. **Plazo:** $\leq$ 12 Horas.

3.2 Mitigación de la Inyección SQL (AUD-002)

- **Acción de Contención Inmediata:** Configurar el archivo `php.ini` de producción poniendo la opción `display_errors = Off`. De esta forma, si el código falla, no mostrará datos de la base de datos en la pantalla.
- **Acción Correctiva Definitiva:** Cambiar el código de `login.php` para que use funciones seguras (como PDO en PHP) que limpien y separen lo que escribe el usuario de las consultas de la base de datos. También hay que dejar de usar MD5 para guardar las contraseñas y cambiarse a un sistema más seguro y moderno como **Argon2id** o **bcrypt**.
- **Responsable:** Equipo de Desarrollo Backend / Ingeniería de Software. **Plazo:** 5 Días.

3.3 Mitigación de la Escalada de Privilegios por Bit SUID (AUD-003)

- **Acción de Contención Inmediata:** Quitar el permiso especial SUID que estaba mal configurado en el binario del sistema operativo usando este comando en la terminal:

```
chmod 0755 /usr/bin/base64
```

- **Remediación Definitiva:** Realizar una revisión manual de los binarios del sistema para confirmar que ninguno conserva el bit SUID sin necesidad real. De forma paralela, eliminar el script residual `test_conn.php`, rotar la clave de API de Stripe expuesta en su contenido, y sustituir la contraseña de acceso SSH por una credencial robusta que resista ataques de fuerza bruta.
- **Responsable:** Administrador de Sistemas Principal / Seguridad de Infraestructura. **Plazo de ejecución:** 48 Horas.

4. Evaluación de Cumplimiento Legal (Compliance)

Los fallos de seguridad críticos e infracciones operativas detectadas durante el ejercicio suponen un incumplimiento directo de los marcos regulatorios nacionales e internacionales aplicables a ShopCloud S.L.:

1. **Reglamento General de Protección de Datos (RGPD):** El almacenamiento de credenciales administrativas en texto plano y el uso de algoritmos criptográficos obsoletos y rotos (MD5) vulneran directamente el **Artículo 32 (Seguridad del Tratamiento)**, que obliga a la empresa a garantizar la confidencialidad, integridad y disponibilidad técnica de los entornos que procesan datos de carácter personal.

2. **Estándar de Seguridad de Datos de la Industria de Tarjetas de Pago (PCI-DSS):** La presencia del archivo residual `test_conn.php` con la API Key de producción de Stripe expuesta abiertamente viola las restricciones de acceso imperativas para datos bancarios.

Nota de Advertencia de Notificación Obligatoria

> **Aviso de Obligación Legal:** Dado que la explotación del fallo de inyección SQL y la presencia del archivo residual confirman el acceso y la posible extracción fraudulenta de bases de datos de producción con datos de carácter personal, en caso de que este escenario ocurra en un entorno productivo real, ShopCloud S.L. tiene la **obligación legal de notificar la brecha de seguridad a la Agencia Española de Protección de Datos (AEPD) y al INCIBE-CERT en un plazo máximo de 72 horas**, evaluando además la comunicación directa con los usuarios afectados según el impacto de los derechos y libertades en juego.

5. Write-Up Técnico de Campo y Anexos

5.1 Flujo de Ataque Controlado (Cadena de Intrusión)

La auditoría comenzó ejecutando una fase de reconocimiento perimetral automatizado mediante la herramienta asistida **WPScan** para identificar componentes desactualizados expuestos en `https://shopcloud.thm`:

```
wpscan --url https://shopcloud.thm --api-token <REDACTED_TOKEN>
```

Tras detectar *WP File Manager v6.8*, se explotó la vulnerabilidad perimetral para obtener una shell reversa con la identidad del servidor web (`www-data`). Desde esa posición interna, se analizó el script del portal de clientes localizado en `/clientes/login.php`, confirmando mediante pruebas manuales de inyección de caracteres una vulnerabilidad de **Inyección SQL** en el motor MariaDB corporativo por falta de sanitización de datos de entrada.

A través de este vector de inyección SQL, se extrajo el contenido de la tabla `users` de la base de datos de producción `db_shopcloud_prod`, obteniendo los hashes criptográficos del personal técnico. Al auditar los permisos locales de la máquina de producción para buscar rutas de escalada, se descubrió la presencia anómala del bit SUID en el binario `/usr/bin/base64`:

```
find / -perm -u=s -type f 2>/dev/null
```

Abusando de esta mala configuración de infraestructura, se logró saltar el control local del sistema operativo leyendo el archivo protegido de contraseñas de Linux, consolidando la intrusión total del servidor con privilegios del superusuario `root`:

```
/usr/bin/base64 /etc/shadow | base64 --decode
```

5.2 Anexo A: Análisis Forense del Log de Autenticación (`auth.log`)

El análisis de los registros internos del servidor del día del compromiso detectó la actividad de fuerza bruta previa al compromiso de la identidad local:

```
May 12 03:14:01 shopcloud sshd[14522]: Failed password for invalid user
   ftpadmin from 10.10.55.201 port 45212 ssh2
May 12 03:14:05 shopcloud sshd[14524]: Failed password for root from
   10.10.55.201 port 45216 ssh2
May 12 03:14:10 shopcloud sshd[14528]: Accepted publickey for www-data
   from 10.10.55.201 port 45220 ssh2: RSA SHA256:X9pZ...
May 12 03:15:22 shopcloud sudo[14601]: www-data : TTY=pts/1 ; PWD=/var/
   www/html ; USER=root ; COMMAND=/usr/bin/python3 -c 'import pty; pty.
   spawn("/bin/bash")'
```

5.3 Anexo B: Evidencia de Permisos en Ficheros Críticos

Volcado de la consola que expone la vulnerabilidad de permisos globales (`777`) en archivos del core y la retención del fichero de respaldo en áreas de descarga indexables de la web:

```
auditor@shopcloud$ ls -la /var/www/html/
-rwxrwxrwx  1 www-data www-data 3215 Apr 20 10:05 wp-config.php
-rw-rw-rw-  1 root     root     1024 Apr 20 08:30 backup_db.sql
```